UNIVERSITE LIBRE
DE BRUXELLES

ZERO DAY VULNERABILITIES

A zero-day as a vulnerability that was maliciously exploited in the wild before a patch was made publicly available

Ch. Cuvelliez – March 12

ZERO DAY VULNERABILITIES

TRENDS

Year 2025 in perspective

- **90 zero-day vulnerabilities** exploited in-the-wild in 2025.
- **Lower than the record high observed in 2023 (100),**
- **Higher than 2024's count (78)**
- **Remains within the 60–100 range** established over the previous four years
- **Structural shift, first identified in 2024, toward increased enterprise exploitation**.
- Sustained **decrease in detected browser-based exploitation**, (historical lows)
- **Increasing abuse of operating system vulnerabilities**
- **State-sponsored espionage groups prioritize edge devices and security appliances as prime entry points**,
  - ✓ Just over half of attributed zero-day exploitation by these groups focused on these technologies.
- **Commercial surveillance vendors (CSVs) focus on mobile and browser exploitation**,
  - ✓ They adapt and expand their exploit chains to bypass more recently implemented security boundaries and other mobile security improvements

ZERO DAY VULNERABILITIES

TRENDS

2026 Zero-Day Forecast

- Enterprise exploitation will expand due to the breadth of applications used across infrastructure.
  - Increased numbers of software, devices, and applications expand attack surfaces, with successful exploitation requiring only a single point of failure to achieve a breach.

- AI automates and scales attacks by accelerating reconnaissance, vulnerability discovery, and exploit development.
  - This reduces the time required for these phases, increasing pressure on defenders to detect and respond to zero-day exploits.

- AI empowers defenders with agentic solutions to enhance security operations.
  - AI agents proactively discover and help patch unknown security flaws, neutralizing vulnerabilities before exploitation.

ZERO DAY VULNERABILITIES

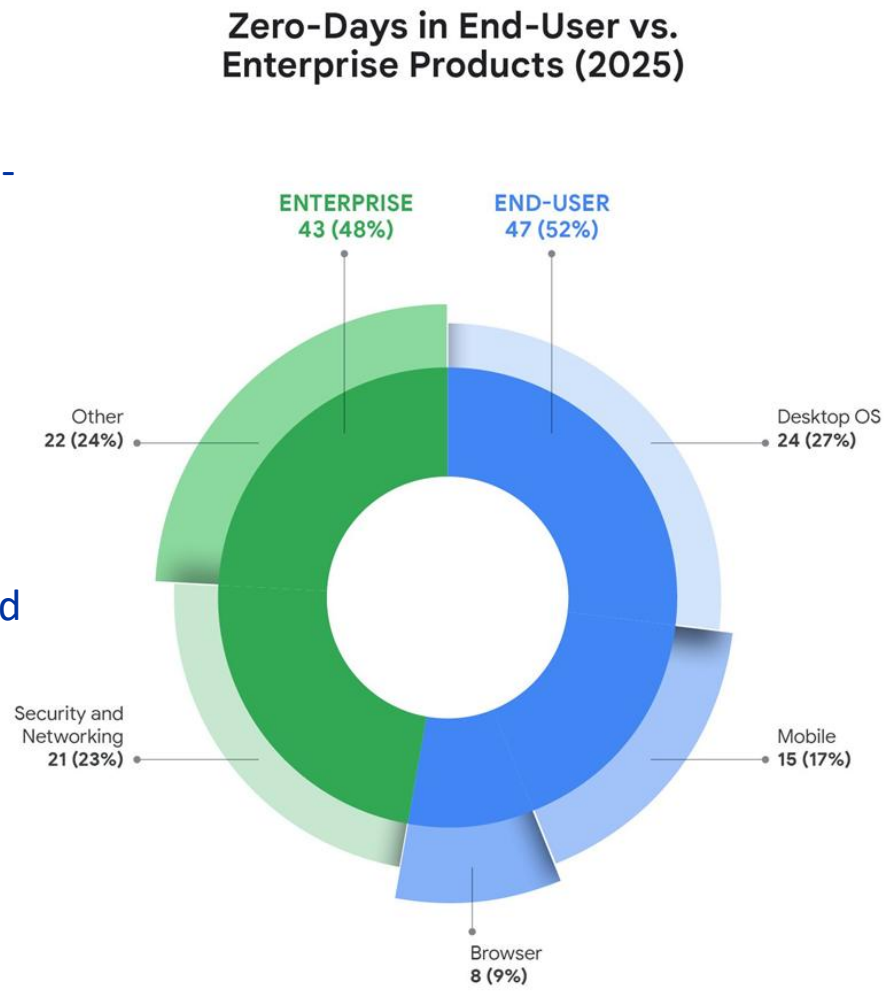
TRENDS

Enterprise Technologies

- Security & Networking vulnerabilities: half (21) of enterprise-related zero-days in 2025, enabling **code execution** and **unauthorized access** via privileged infrastructure.
- Common issues: **lack of input validation and incomplete authorization, reflecting persistent but fixable systemic failures** with proper standards.
- **Edge devices (routers, switches, security appliances) are high-value perimeter targets due to absent EDR technology**, creating detection blind spots.

Enterprise Softwares

- Enterprise Software: High-profile exploitation of enterprise tools and virtualization technologies demonstrates that attackers are deeply embedding themselves in critical business infrastructure.



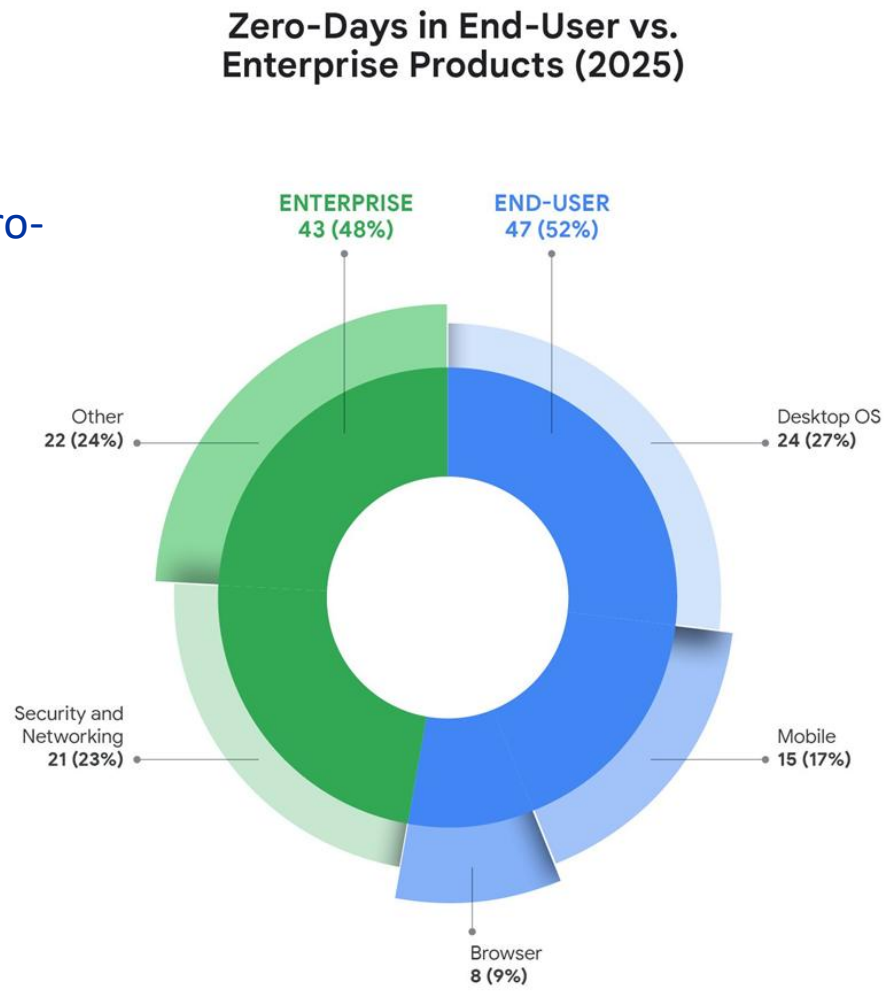
ZERO DAY VULNERABILITIES

TRENDS

End User Platforms and Products

- **Operating Systems (OSs):** OSs, desktop and mobile = the most exploited product category in 2025, accounting for 44% (39) of all zero-days.
- **Increase vs previous years** : 31 in 2024, and 33 in 2023) and proportions of total zero-day exploitation: 40% in 2024 and 33% in 2023).
- **Desktop OS zero-days have fluctuated between 16 and 23 annually while maintaining a gradual upward trajectory**

  - Foundational role of these platforms and the massive scale of effect permitted by OS-level exploitation.

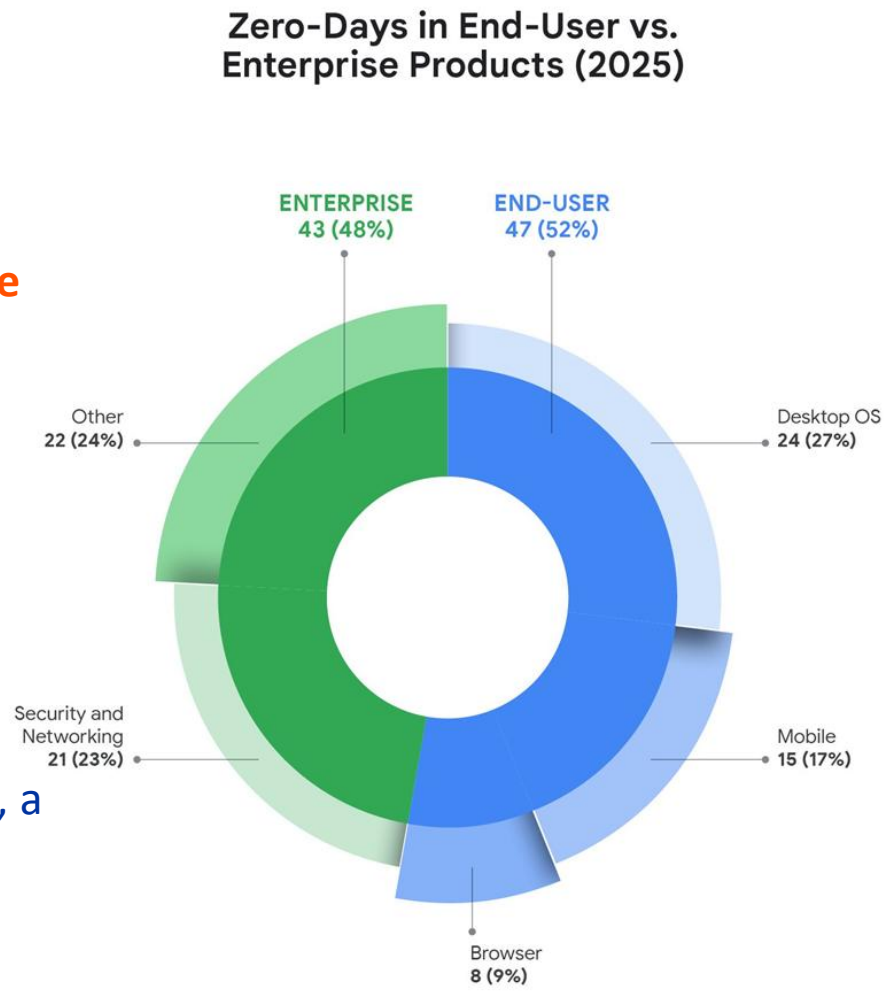


ZERO DAY VULNERABILITIES

TRENDS

End User Platforms and Products

- **Mobile OS exploitation** increased, with 15 zero-days in 2025 vs. 9 in 2024 (after 17 in 2023).
  - ✓ Temporary 2024 decline followed by resurgence due to: **multiple exploit chains using 3+ vulnerabilities for one objective.**
  - ✓ **More complete exploit chains discovered in 2025**, compared to partial chains or single vulnerabilities previously.
  - ✓ **Threat actors, especially CSVs, developed novel techniques to bypass new security boundaries**
- **Browsers:** accounted for less than 10% of 2025 zero-day exploitation, a decrease from the browser-heavy years of 2021-2022. Browser hardening measures are working

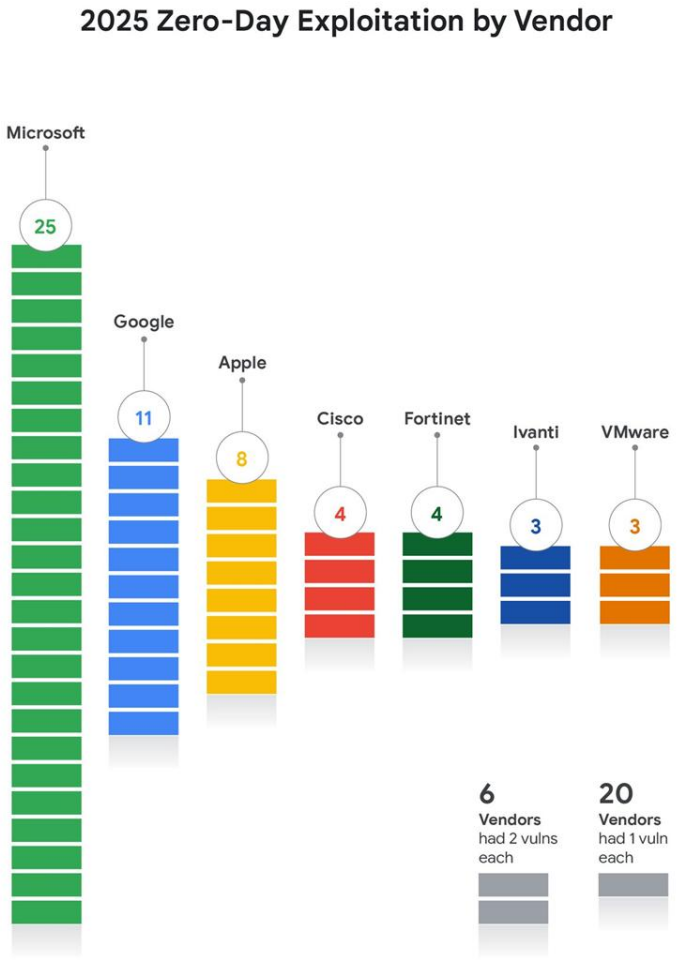


ZERO DAY VULNERABILITIES

TRENDS

Exploitation by Vendor

- **Big tech experiencing the most zero-day exploitation and security vendors following directly behind**
  - **Big tech companies dominate user bases for consumer products:** desktop OSs, browsers, and mobile systems are prime exploitation targets.
  - **Cisco and Fortinet remain top targets among networking and security vendors.**
  - **Ivanti and VMware** face ongoing exploitation**, highlighting threat actors' high interest in VPNs and virtualization platforms**.
  - **20 vendors exploited by just one zero-day each**: threat actors' succeed in targeting varying vendors and products to find successful footholds in desired targets



ZERO DAY VULNERABILITIES

TRENDS

Types of Exploited Vulnerabilities

- **zero-day exploitation** was primarily used to achieve **remote code execution**, followed by **gaining privilege escalation**
  - Both code execution and unauthorized access were common goals of network and edge infrastructure exploitation.
  - **Injection & Deserialization:** Command injection and deserialization + key vectors for reliable remote code execution (RCE) in enterprises, simpler than memory corruption = SQL/command injection enabled initial access via web-facing appliances.

(Deserialization = converting a serialized data stream like JSON, XML, or binary formats back into a usable object in memory, commonly used for data transmission or storage in applications: Attackers modify serialized objects to include executable code or alter application logic).

ZERO DAY VULNERABILITIES

TRENDS

Types of Exploited Vulnerabilities

- **zero-day exploitation** was primarily used to achieve **remote code execution**, followed by **gaining privilege escalation**

  - **Memory Corruption: Accounted for ~35% of vulnerabilities, with use-after-free (UAF) and out-of-bounds writes dominant in browsers and OS kernels.**

  - **Access Control:** Authentication/authorization bypasses were prevalent, especially on edge devices securing perimeters and admin interfaces.

  - **Logic & Design Flaws:** Common in enterprise appliances, these architectural weaknesses are hard to detect as software behaves as designed.

  (Use-after-free (UAF) is a memory corruption vulnerability where a program accesses a pointer to memory after that memory has been freed or deallocated, creating a "dangling pointer: memory is dynamically allocated used, then freed (free/delete), but the pointer isn't nullified or cleared. The OS may reallocate that freed memory to another object)

ZERO DAY VULNERABILITIES

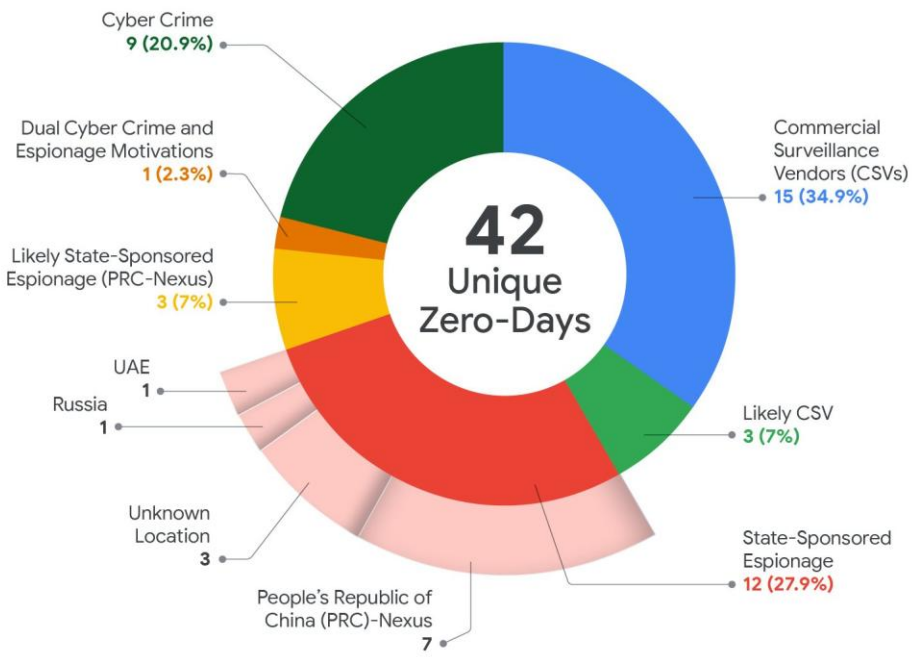
TRENDS

Who Is Driving Exploitation

- **Commercial Surveillance Vendor Exploitation Grows**
  - ✓ Historically, **traditional state-sponsored cyber espionage groups have been the most prolific** attributed users of zero-day vulnerabilities.
  - ✓ **Now, the increase of zero-day exploitation attributed to CSVs and their customers points their growing ability** of these vendors to provide zero-day access to a wider range of threat actors than ever before.

- **People's Republic of China (PRC)-Nexus Cyber Espionage Groups Still Most Prolific**
  - ✓ **Mass exploitation of vulnerabilities indicates PRC-nexus espionage operators are increasingly skilled at developing, sharing, and distributing exploits among themselves.**
  - ✓ **Historically, zero-day exploits were closely guarded and used only by the most well-resourced threat groups.**

Attributed 2025 Zero-Day Exploitation



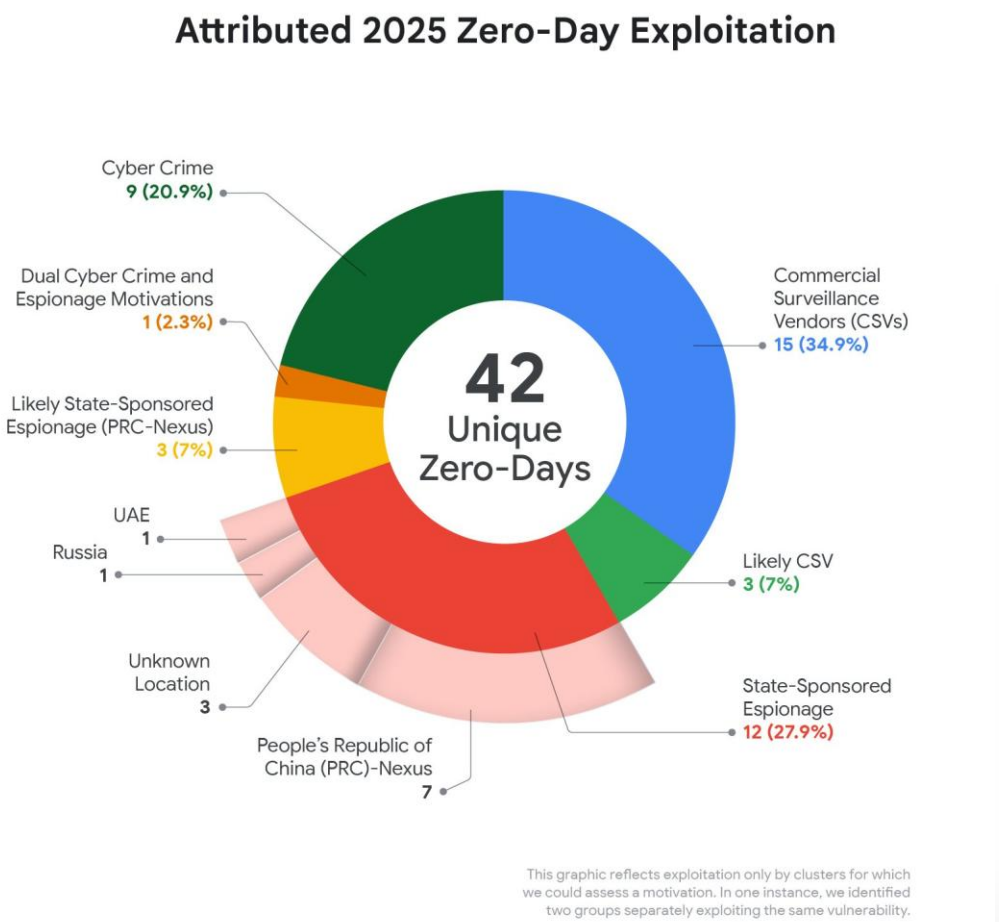
This graphic reflects exploitation only by clusters for which we could assess a motivation. In one instance, we identified two groups separately exploiting the same vulnerability.

ZERO DAY VULNERABILITIES

TRENDS

Who Is Driving Exploitation

- **Financially Motivated Exploitation Spikes**
  - Exploitation in 2025 of nine zero-days by likely or confirmed financially motivated threat groups, including the reported exploitation of two zero-days in operations that led to ransomware deployment
  - Financially motivated actors, including ransomware affiliates, were linked to a substantial number of enterprise exploits



ZERO DAY VULNERABILITIES

TRENDS

Mitigating Zero-Day Threats

- **Vulnerability exploitation = number one initial access vector, outnumbering other vectors like stolen credentials and phishing**

- **Architectural Hardening & Surface Reduction**

  - ✓ **Properly segment DMZ, firewalls, and VPNs** from critical assets like core networks and domain controllers to block lateral movement from compromised external components.

  - ✓ **Monitor application execution flows to detect and block unauthorized database queries or shell commands.**

  - ✓ **Avoid exposing device network ports to the internet** unless strictly necessary.

ZERO DAY VULNERABILITIES

TRENDS

Mitigating Zero-Day Threats

- **Vulnerability exploitation = number one initial access vector, outnumbering other vectors like stolen credentials and phishing**

- **Personal devices:**
  - ✓ **Turn off personal devices or leave them at home during high exploitation risk**.
  - ✓ **Enable before first unlock (BFU)** mode and USB restricted mode against physical attacks:
    - Forensic tools used by law enforcement or hackers often rely on "After First Unlock" (AFU) states, where encryption keys are already sitting in the RAM. By keeping a device in BFU, the data is mathematically inaccessible without the passcode. Use it when passing the border !
  - ✓ **Disable cellular, WiFi, and Bluetooth during close proximity attack risks**.
  - ✓ **Apply patches immediately upon availability**.
  - ✓ Use ad blockers, configure Apple ad privacy settings, and enable Android privacy sandbox.
  - ✓ **Remove unused apps and disable unnecessary services/features, including default-enabled ones.**

ZERO DAY VULNERABILITIES

TRENDS

Mitigating Zero-Day Threats

- **Vulnerability exploitation = number one initial access vector, outnumbering other vectors like stolen credentials and phishing**

- **Infrastructure::**
  - ✓ Enforce strict driver blocklists (Since the weak driver is digitally signed by a trusted vendor, the OS allows it) and monitor for unusual kernel-level activity that standard EDR tools may miss (If the kernel is compromised, the OS can no longer be trusted to report the truth.Standard EDR tools often operate primarily in "user-land" or rely on specific hooks in the kernel)
  - ✓ Define a baseline of normal system processes to detect "Living off the Land" (LotL= attackers use legitimate, pre-installed system tools to perform malicious actions.) techniques and persistence methods.
  - ✓ Use canary tokens and decoy files to generate reliable alerts indicating potential lateral movement.